

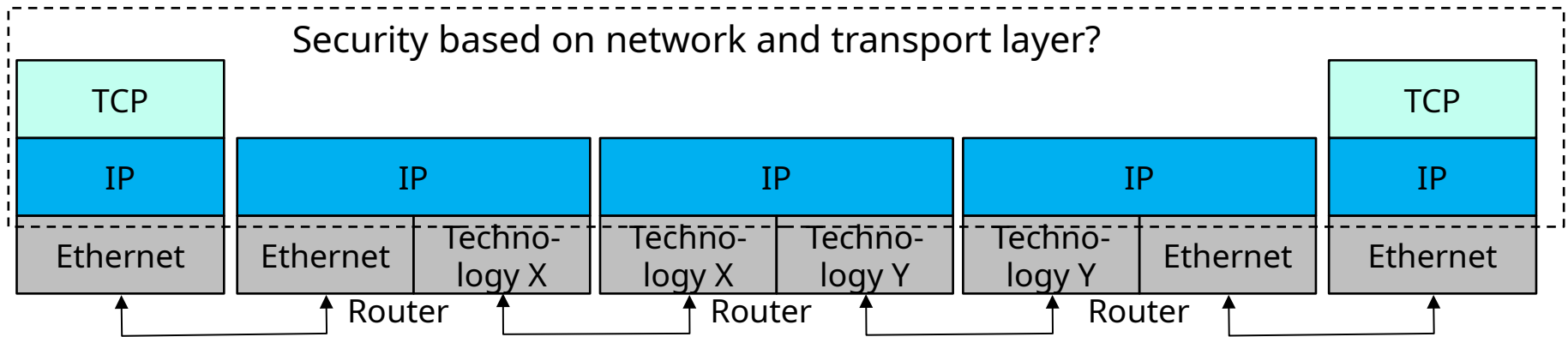
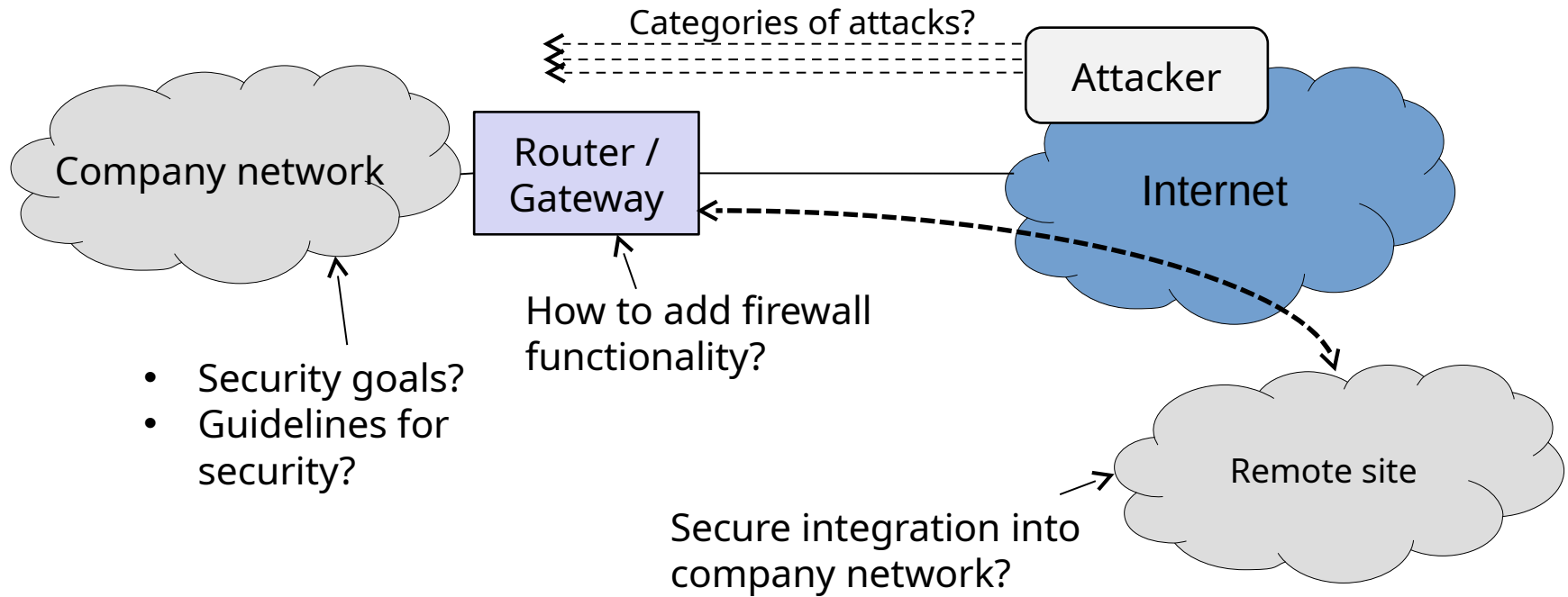
Advanced Computer Networks

Virtual Private Networks / Firewalling

Winter term 2025/26

marius.feldmann@tu-dresden.de

Introduction



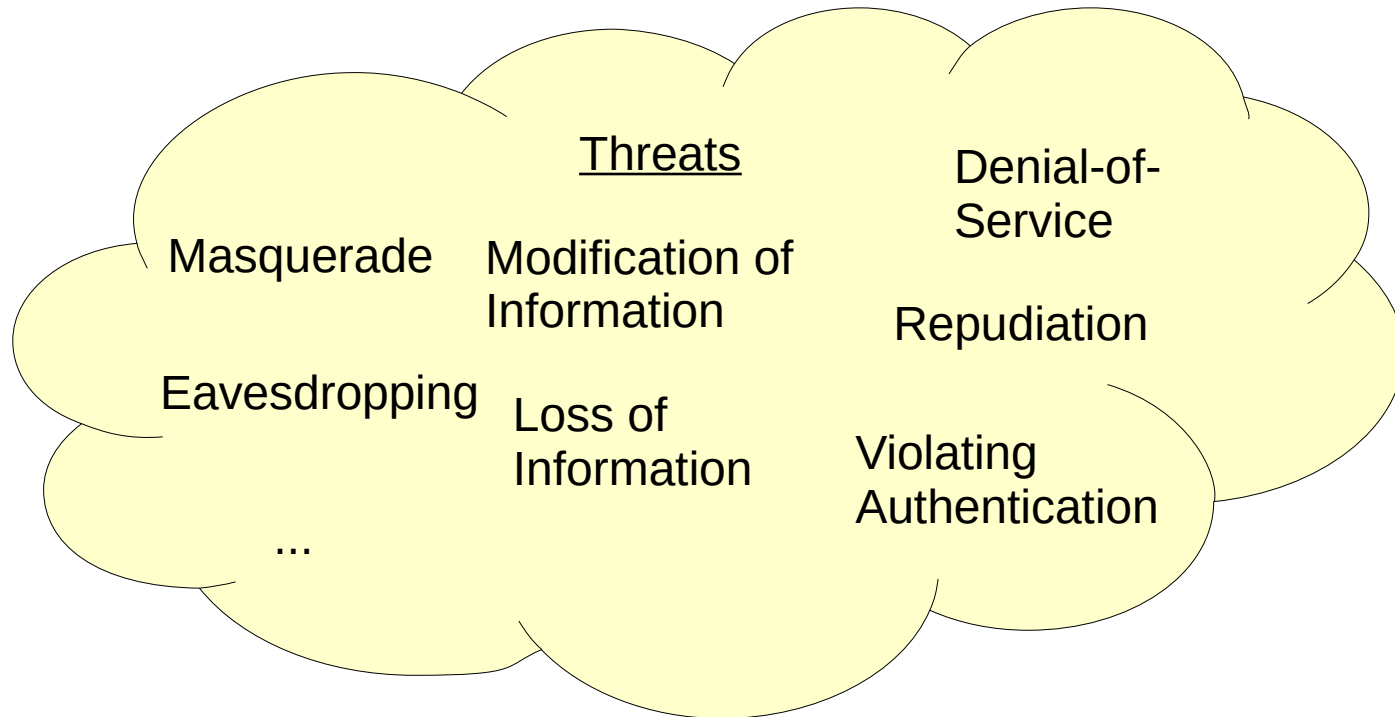
Outline

1. Terminology
2. Security goals and threats
3. IT basic protection / BSI Grundschutz and ISO 27001
4. Virtual Private Networks (VPNs)
 - IPsec
 - Security Association
 - Tunnel and Transport mode
 - Authentication Header
 - Encapsulated Security Payload
 - Wireguard
 - SSH-based
5. Firewalls
 - Overview
 - Netfilter / Iptables
 - XDP-based
6. Overview of Intrusion Detection / Response Systems

Terms

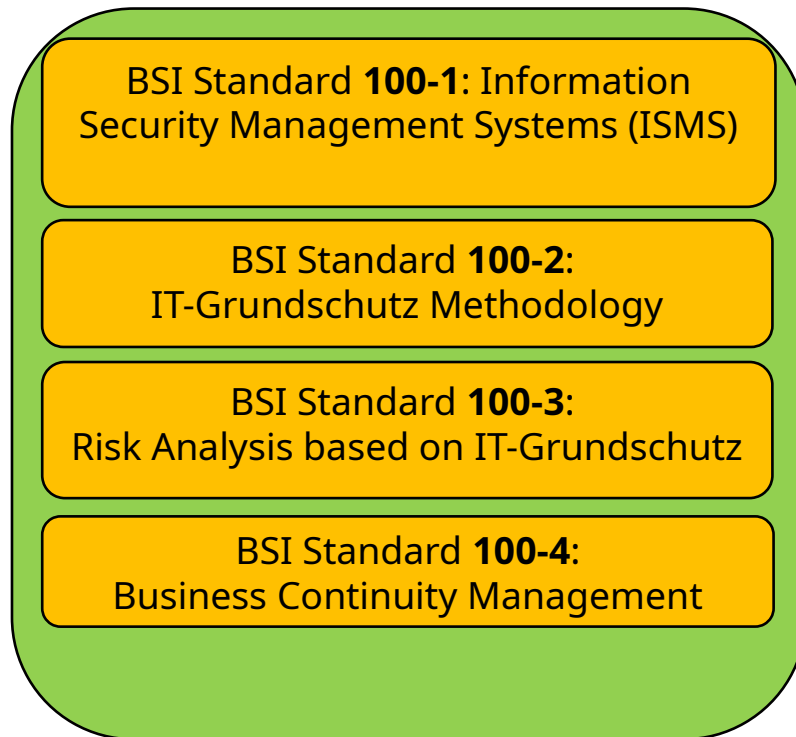
- **Threat:** Potential event or series of events which challenge(s) fulfilment of one or more security goals
- **Attack:** Realization of a threat
- **Selected technical security goals:**
 - Confidentiality** • Transmitted data should not be available to unauthorized parties
 - (Data) Integrity** • Unauthorized modification of data does not happen without detection of this modification
 - Accountability** • Entity being the source of an event or a series of events can be uniquely identified in the system
 - Availability** • Offered services have to work in the correct manner and have to be reachable by communication partners
- Collection of terms for the security domain be found in RFC 4949 "Internet Security Glossary, Version 2"

Threats



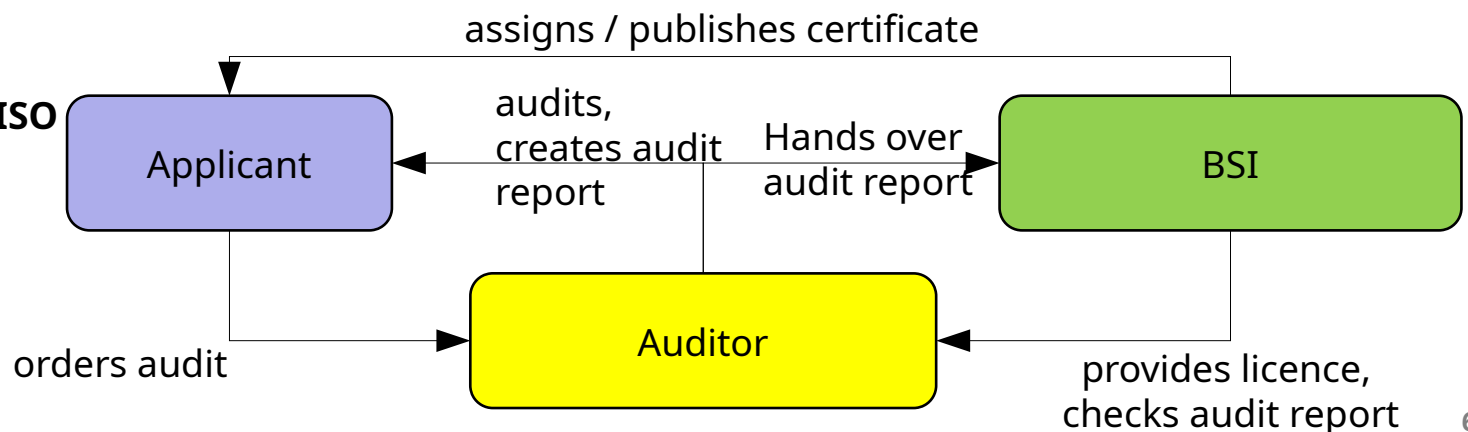
- Threats can be associated to security goals:
 - Eavesdropping is a threat to confidentiality
 - Denial-of-Service is a threat to availability
- Often attacks combine realization of different threats
 - Eavesdropping and masquerade are often combined

IT basic protection



- IT basic protection ("Grundschutz") offers a framework for securing organizations fundamentally
- In addition to BSI standards, IT basic protection catalogs are published
- Catalogs contain information on building blocks (networks, applications, etc.), threats and measures

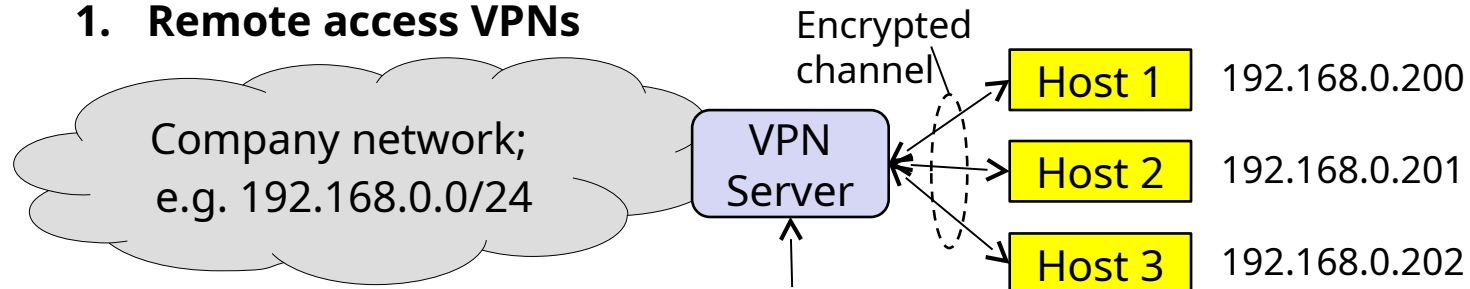
**Certification
based on
Grundschutz (ISO
27001)**



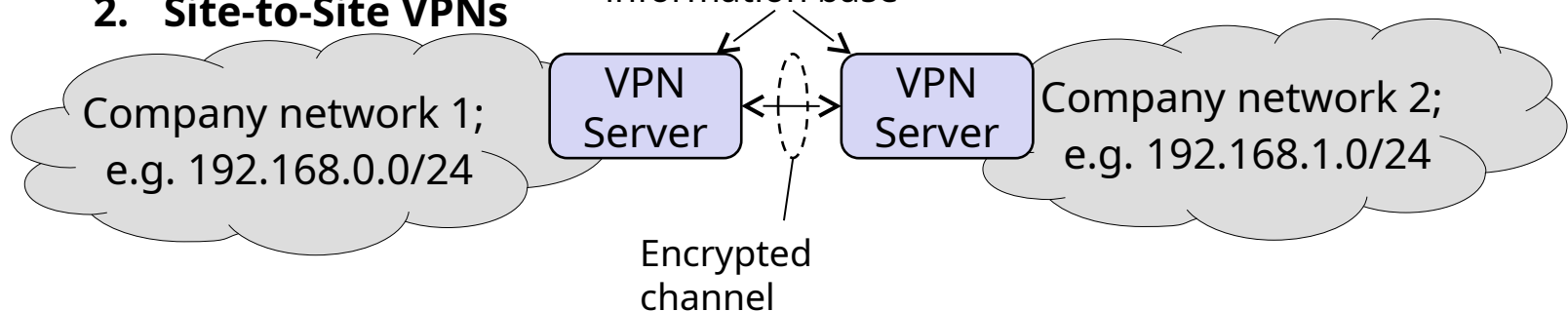
Virtual Private Networks

- A Virtual Private Network (VPN) is an approach to interconnect remote networks via the Internet or a WAN in a secure manner
- Selected approaches for implementing VPNs:
 - Internet Protocol Security (IPsec)
 - Wireguard
 - Secure Shell (SSH) VPN
 - Transport Layer Security
- Fundamental classification of VPNS

1. Remote access VPNs

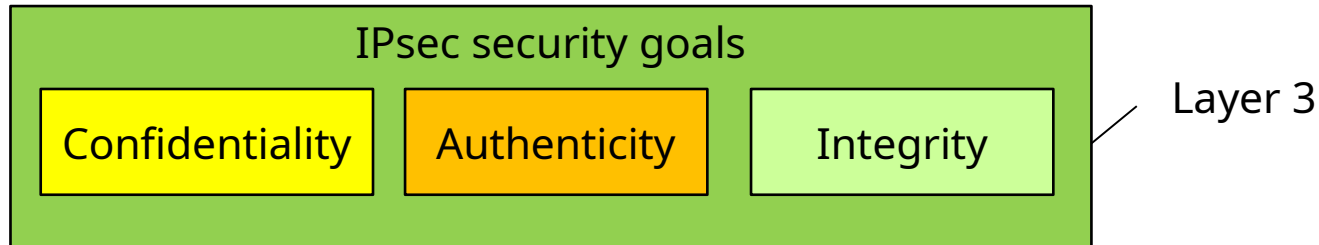


2. Site-to-Site VPNs



IPsec – Overview

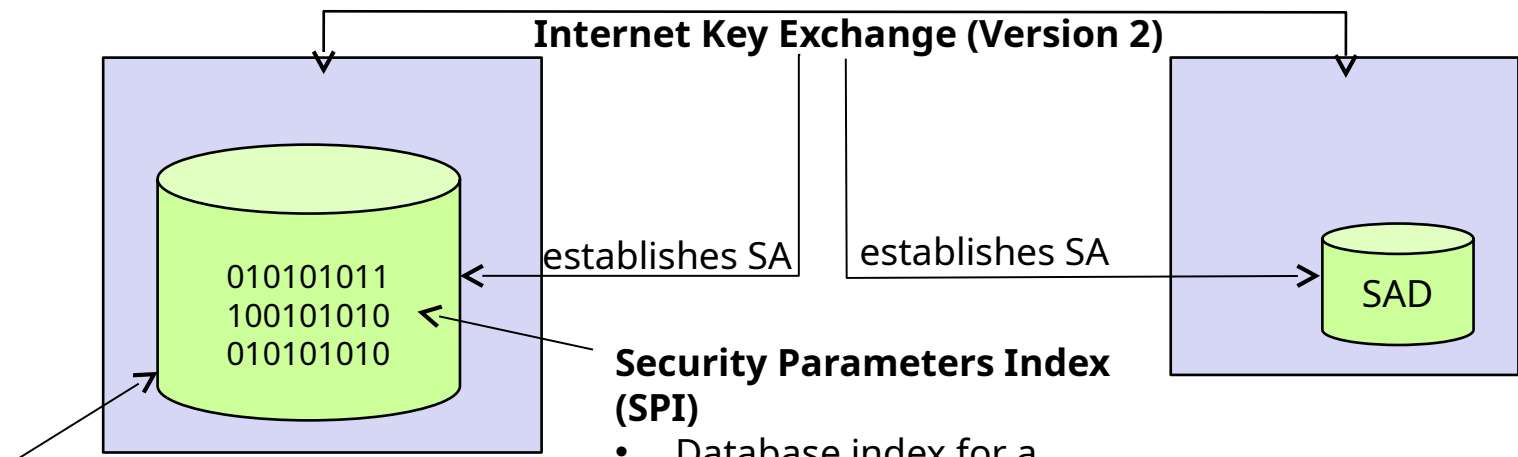
- In contrast to approaches, such as Transport Layer Security or MACsec, IPsec offers security on Layer 3



- Overview of IPsec is provided in RFC 4301
- Specification of IPsec consists of three parts
 - 1. Protocols**
 - Authentication Header (AH) – RFC 4302
 - IP Encapsulating Security Payload (ESP) – RFC 4303
 - 2. Cryptographic Algorithms** – RFC 8221, RFC 8247
 - 3. Key Exchange Mechanism** – RFC 7296
- IPsec is designed in a modular manner with various configuration options to determine the security scope and granularity on a case to case basis

IPsec – Security Association

- Information definition of a **Security Association (SA)** in RFC 4301:
*"A SA is a **simplex "connection" that affords security services to the traffic carried by it. [...] If both AH and ESP protection are applied to a traffic stream, then two SAs must be created and coordinated to effect protection through iterated application of the security protocols. To secure typical, bi-directional communication between two IPsec-enabled systems, a pair of SAs (one in each direction) is required. IKE explicitly creates SA pairs in recognition of this common usage requirement.**"*



Security Association Database (SAD):

- Local database for security associations
- Contains for each SA information about the used algorithms and keys

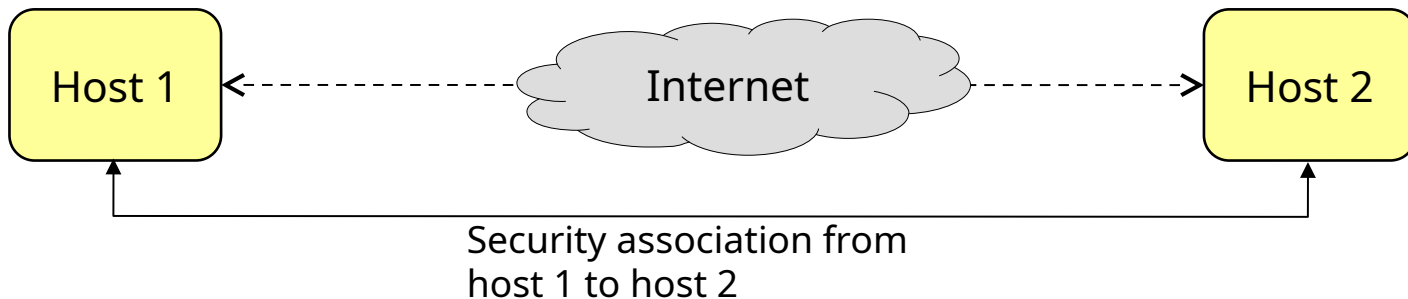
Security Parameters Index (SPI)

- Database index for a specific SA to access information required for cryptographic operations

IPsec – Transport and tunnel mode

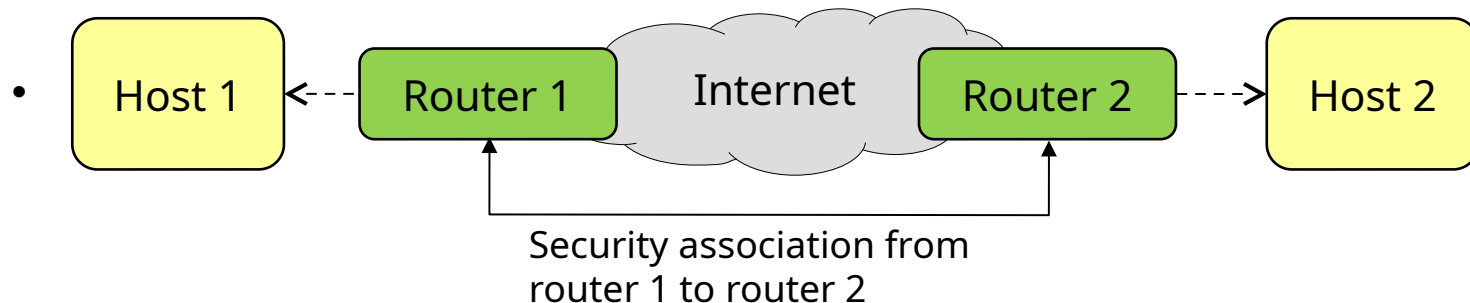
- **Transport mode:**

- Communication endpoints are also the cryptographic endpoints
- Data within the IP packets are encrypted / authenticated



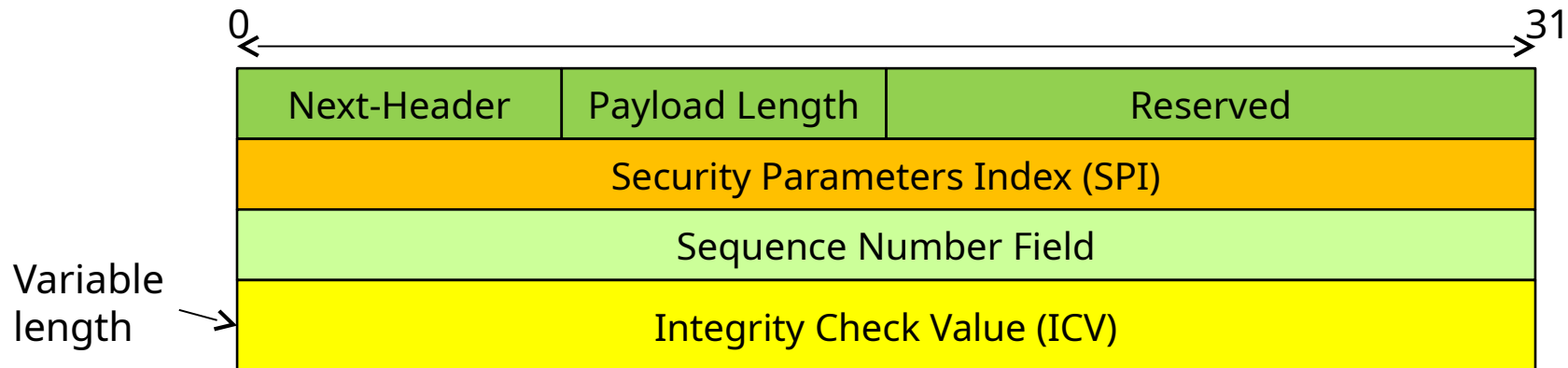
- **Tunnel mode:**

- At least one cryptographic endpoint is not a communication endpoint
- Full IP packet is encrypted / authenticated and encapsulated into a new IP packet
- Used for VPN solutions



IPsec – Authentication Header (AH)

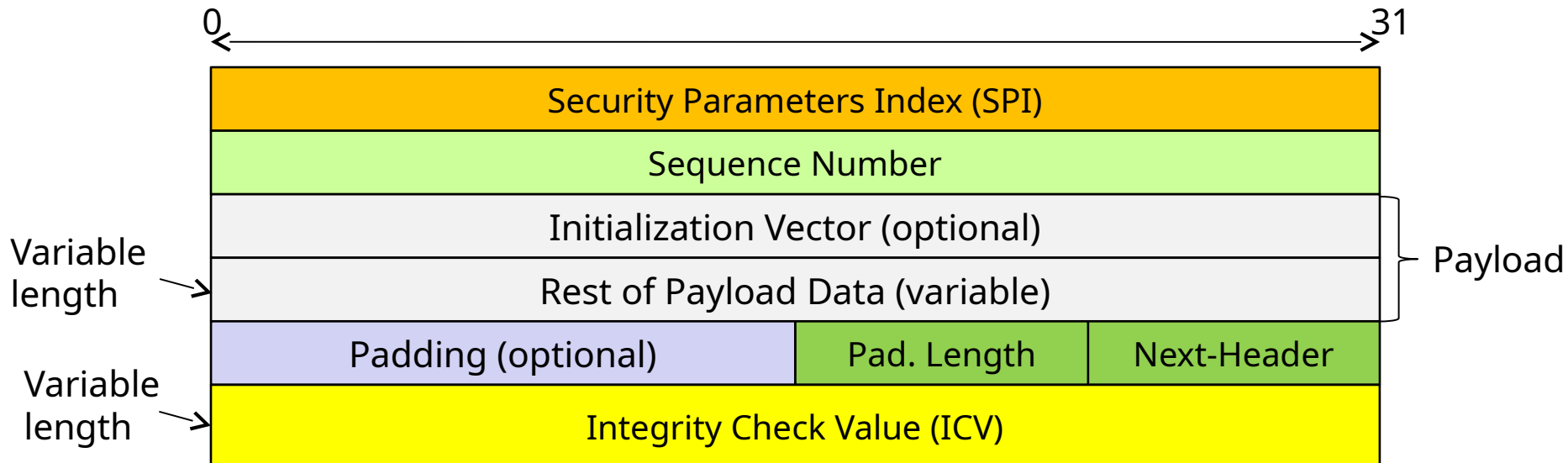
- IP Authentication Header (IP protocol number 51) ensures connectionless data integrity and data origin authentication of IP packets plus optional protection against replay attacks



- Next header: Identifier for encapsulated protocol (e.g. 6 = TCP)
- Payload Length: Length of the header in 32-bit words minus 2
- Security Parameters Index: Identifies a security association together with the IP address of the recipient
- Sequence Number Field: Unique number incremented with each packet that protects against replay attacks
- Integrity Check Value: Calculated using IP or extension header fields that either remain unchanged in transit or assume predictable values, the AH header (ICV field is set to zero) and all data encapsulated by the AH header

IPsec – Encapsulated Security Payload (ESP)

- IP Encapsulated Security Payload (IP protocol number 50) provides confidentiality, connectionless data integrity and data origin authentication plus optional protection against replay attacks



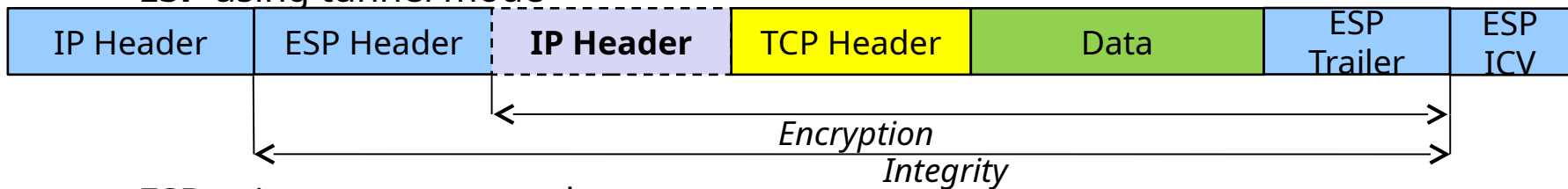
- Payload:
 - Initialization Vector: For several cryptographic algorithms required random vector
 - Rest of Payload Data: Variable-length (encrypted) payload data taken from the original IP packet
- Next Header: Specifies type of data included as payload data
- Part after payload and before ICV is named "trailer"

IPsec – AH and ESP in the tunnel and transport mode

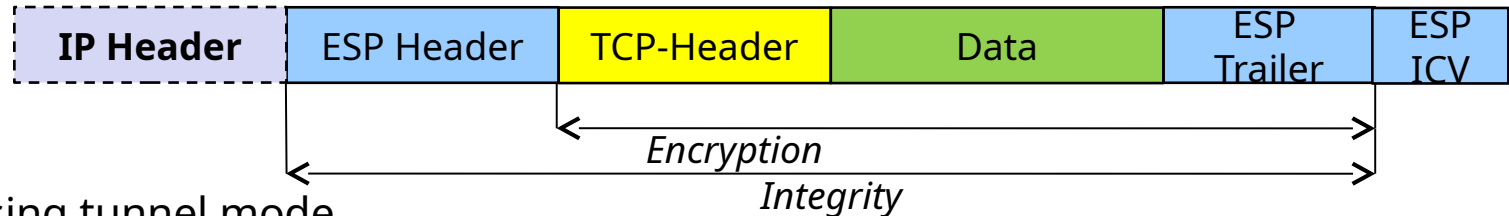
- Original IP packet



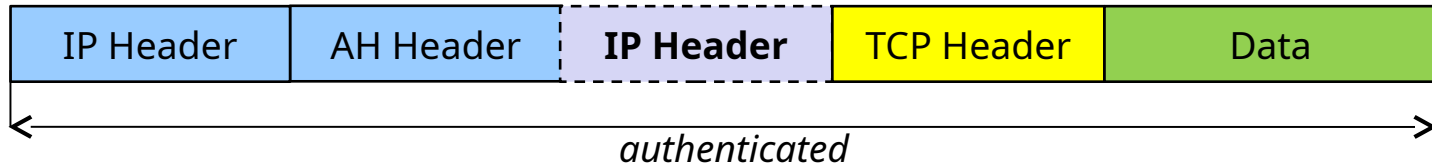
- ESP using tunnel mode



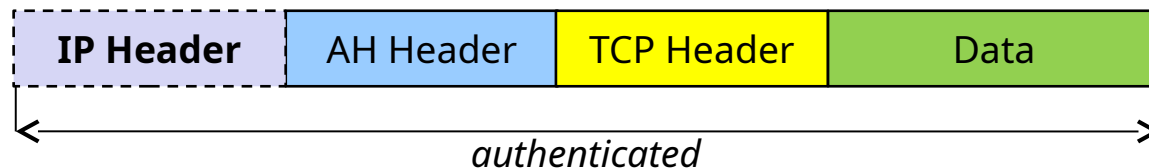
- ESP using transport mode



- AH using tunnel mode



- AH using transport mode



IPsec – Comments

Statements by John Gilmore about IPsec [1]:

- *„NSA employees participated (sic) throughout, and occupied leadership roles in the committee and among the editors of the documents.”*
- *„The resulting standard was incredibly complicated -- so complex that every real cryptographer who tried to analyze it threw up their hands and said, ‘We can't even begin to evaluate its security unless you simplify it radically’.”*

Statements by Theo de Raadt [2]:

- *„I have received a mail regarding the early development of the OpenBSD IPSEC stack. It is alleged that some ex-developers (and the company they worked for) accepted US government money to put backdoors into our network stack, in particular the IPSEC stack. Around 2000-2001. Since we had the first IPSEC stack available for free, large parts of the code are now found in many other projects/products.”*

Evaluation from 2003 by Niels Ferguson and Bruce Schneier:

- <https://www.schneier.com/paper-ipsec.pdf>

[1] <http://www.metzdowd.com/pipermail/cryptography/2013-September/017218.html>

[2] <http://marc.info/?l=openbsd-tech&m=129236621626462>

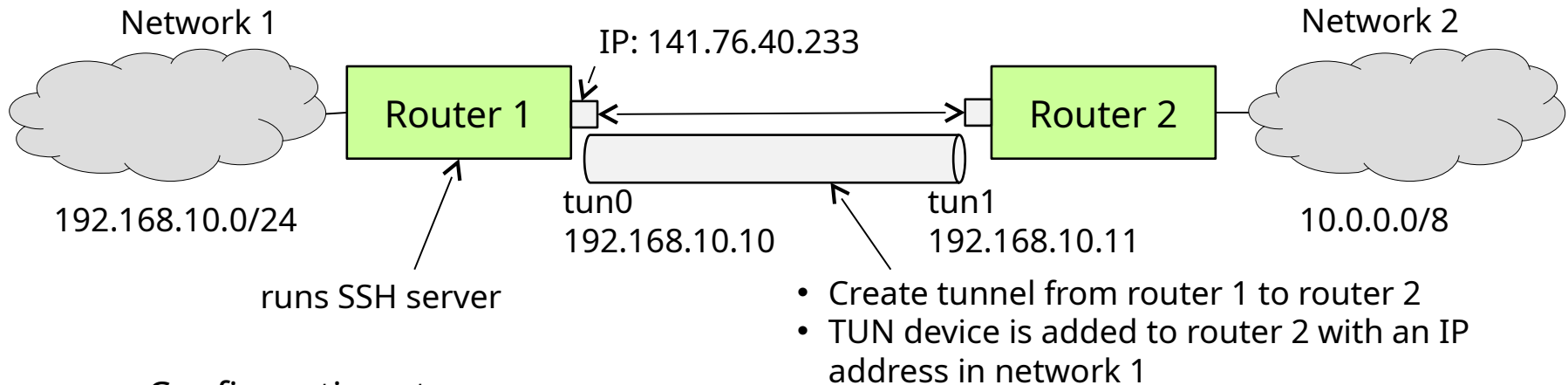
Wireguard

- UDP-based VPN solution under GPLv2 that is integrated directly into the Linux kernel (also available for Windows, FreeBSD or macOS, among others)
- A small number of cryptographic methods are used, e.g. only ChaCha20 (see RFC 8439) for encryption
- Code base significantly more compact compared to e.g. IPsec
- Can be used for "meshed VPNs" (VPNs with more than 2 sites)
- Establishment of a secure connection takes one RTT
- Identification of peers is done strictly on layer 3 and only packets in specified IP address ranges ("allowed-ips") are accepted on a Wireguard interface -> approach simplifies firewall rules
- Configuration involves only a few steps:

```
# ip link add dev wg0 type wireguard
# ip addr add 192.168.42.1/24 dev wg0
# wg set wg0 listen-port $L_PORT private-key $PATH_TO_KEY_FILE
# wg set wg0 peer $PUBLIC_KEY_PEER preshared-key \
    $PSK endpoint $IP_PEER:$R_PORT allowed-ips 192.168.42.2/32
# ip link set wg0 up
```

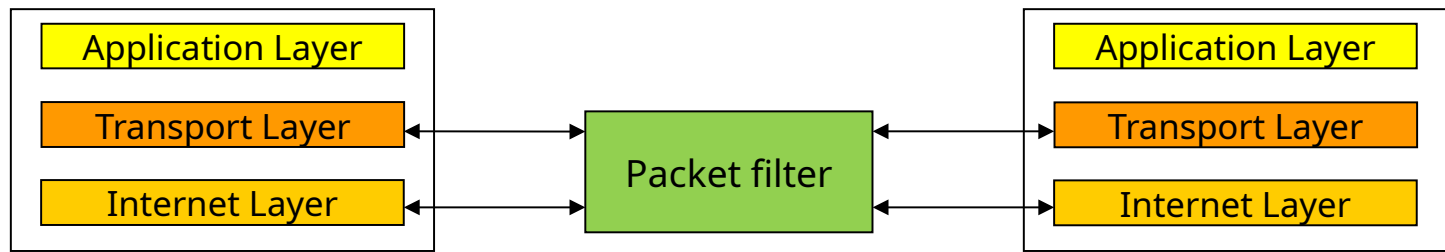

VPN via Secure Shell (SSH)

- VPN can be established using TUN devices based on SSH (TCP-based)
- Approach:

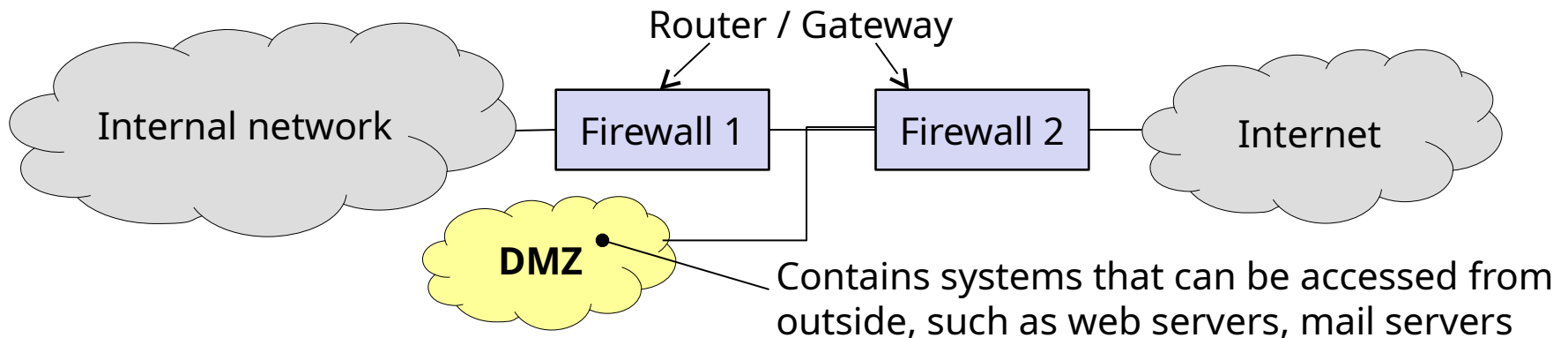


- Configuration steps:
 1. Router 2 has to establish an SSH connection to router 1 and to bind it to a locally created virtual interface (TUN/TAP device)
 - `sudo ssh -w 0:0 141.76.40.233`
 2. Assigning IP addresses to the created interface on router 1 (192.168.10.10) and on router 2 (192.168.10.11)
 3. Creating entries in the Forwarding Information Base on the routers, e.g.
 - `ip route add 192.168.10.0/24 via 192.168.10.10` (on router 2)

Firewalls



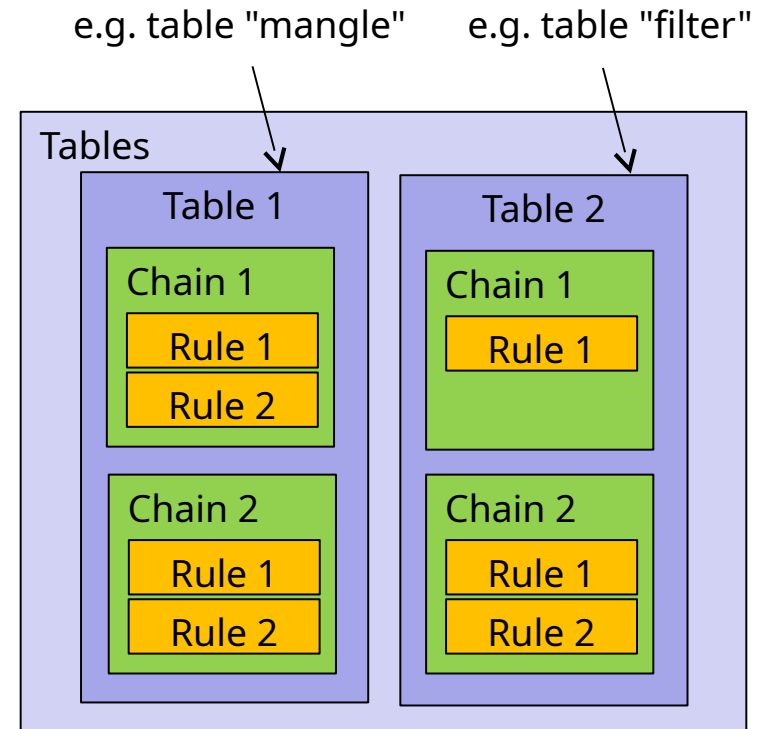
- Firewall according to RFC 4949: “An internetwork gateway that restricts data communication traffic to and from one of the connected networks...”
- Example setup for firewall use:
- Two-tier firewall concept with demilitarized zone (DMZ) / buffer zone (according to RFC 4949, the term DMZ should no longer be used):



- Zero Trust Networks: No entity inside or outside of your own network is trusted a priori
-
- For implementation on the network and transport layer, common operating systems offer options for defining packet filters, e.g. based on Netfilter (Linux), pf (OpenBSD, DragonFly BSD, ...)

Netfilter / Iptables

- Netfilter is a software layer in the Linux kernel that allows the registration of callback functions for packet processing
- Use for automatic response to packets to implement packet filters (and for other mechanisms such as NAT/PAT)
- Netfilter defines five "hooks" for callback functions: PREROUTING, INPUT, OUTPUT, FORWARD and POSTROUTING



- iptables = Tool for managing chains of firewall rules assigned to "hooks"
- Chains are assigned to tables that allow determining the order in which chains are evaluated

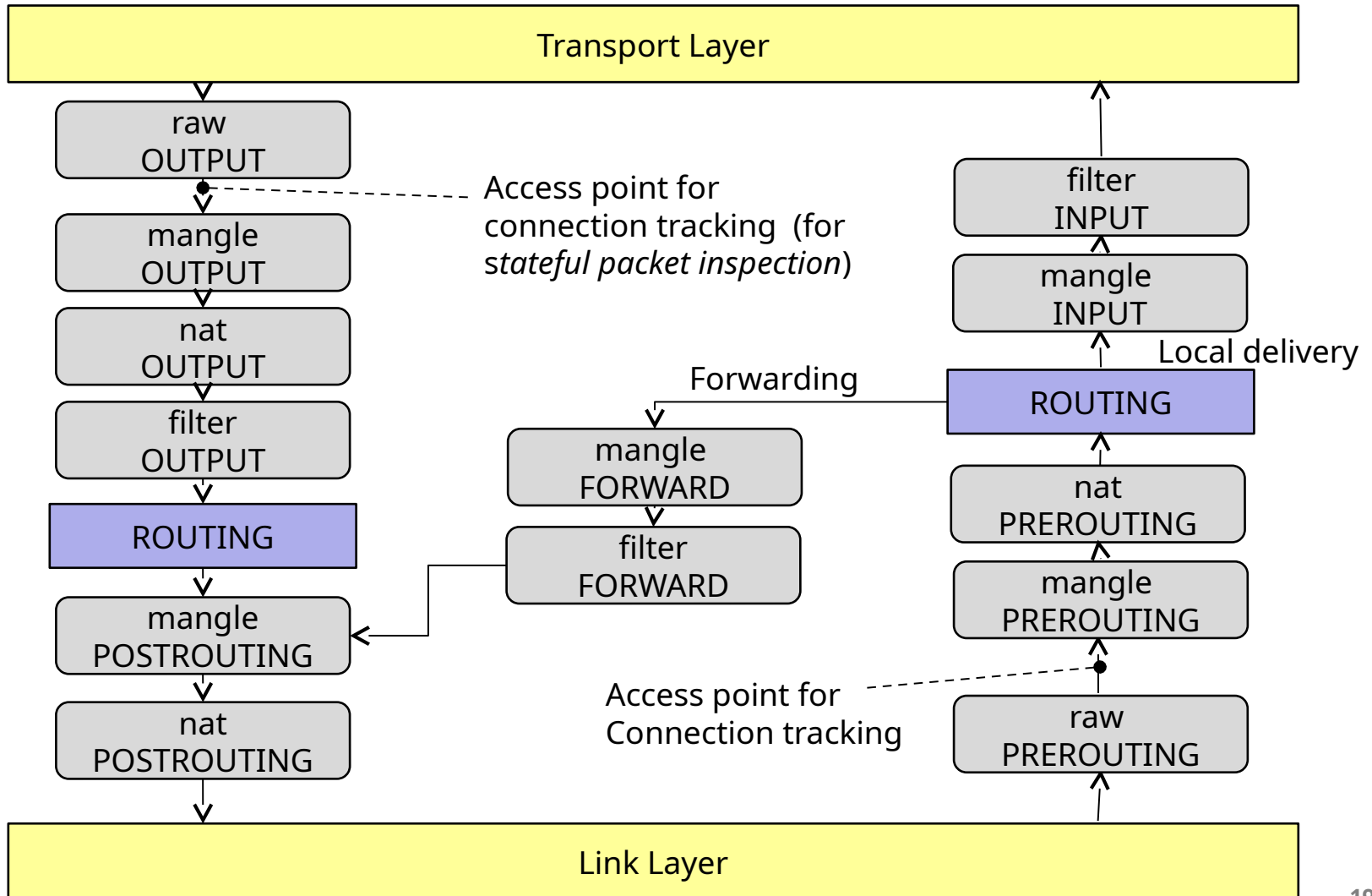
Example of defining firewall rules using iptables:

```
# iptables -A INPUT -p tcp ! --syn -m state --state NEW -j DROP
# iptables -A INPUT -j ACCEPT -p all -s 192.168.1.0/24 -i eth1
```

↗
No table specified → Default table = filter

Netfilter / Iptables

- Packet flow through the tables associated to the modules "*raw*", "*mangle*", "*nat*" and "*filter*"



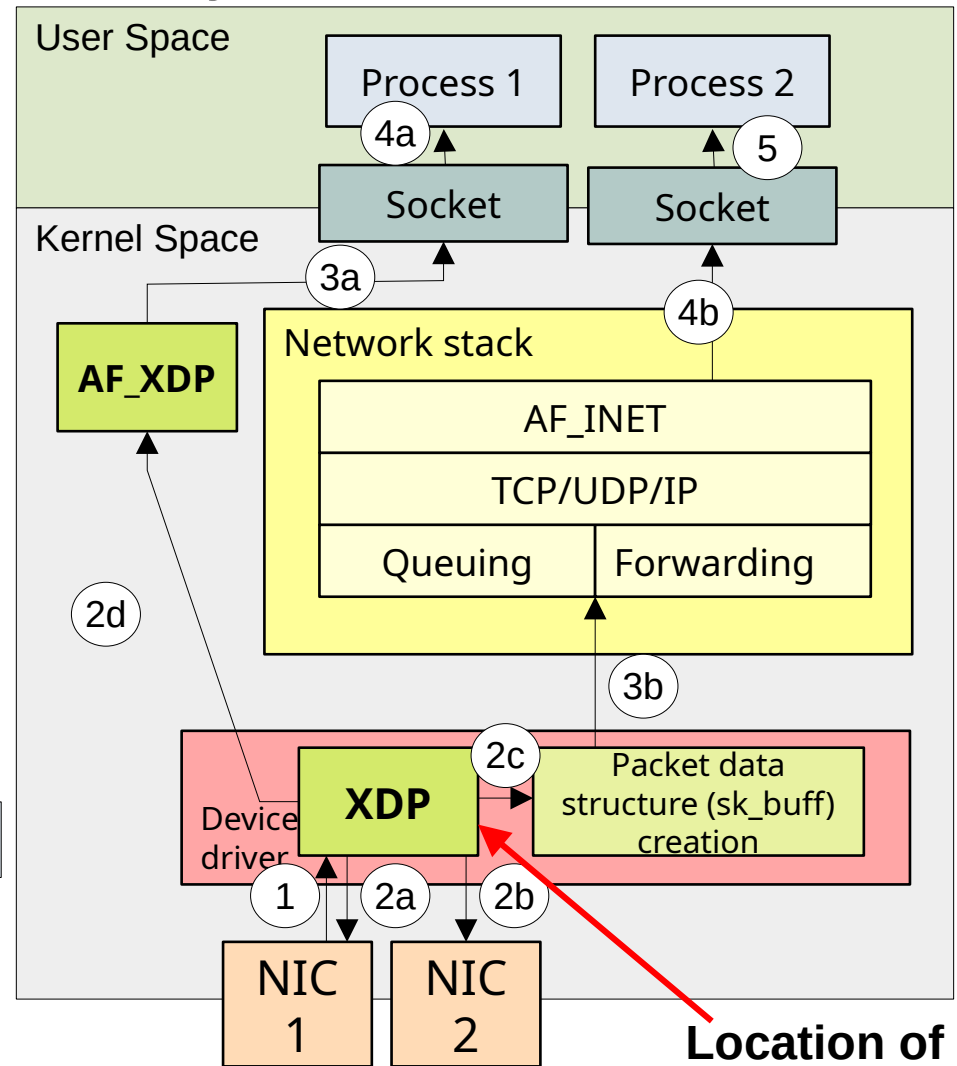
Express Data Path / (extended) Berkley Packet Filter

- Extended Berkley Packet Filter (eBPF) is a kind of virtual machine in the Linux kernel for - among other user cases - processing packets,
- Express Data Path (XDP) is a framework for using (e)BPF
- XDP uses (e)BPF at the earliest possible point after receiving a packet
- Used for e. g.:
 - DDoS mitigation, firewalling and monitoring of network traffic
- XDP programs can be loaded at runtime, e.g. via ip

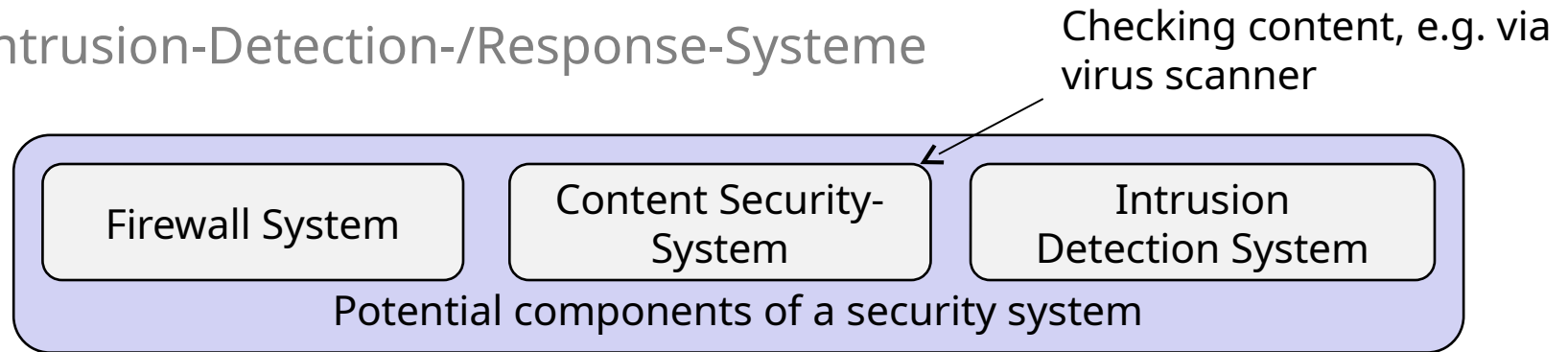
```
# ip link set dev eth0 xdp obj somexdpprog.o
```

- Overview paper: "The eXpress Data Path: Fast Programmable Packet Processing in the Operating System Kernel"; see:

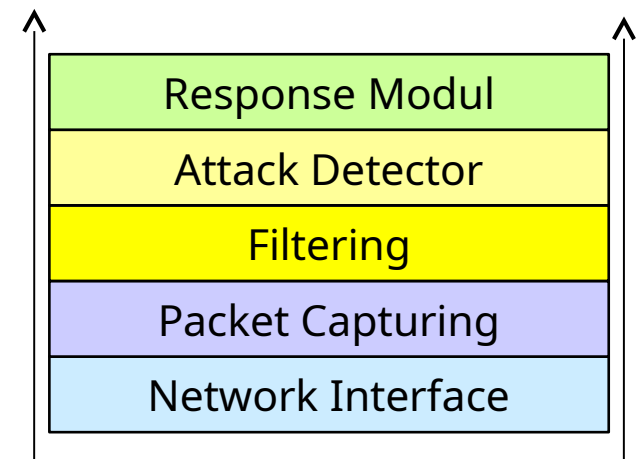
- <https://github.com/tohojo/xdp-paper>
- Option 2e is to drop the packet



Intrusion-Detection-/Response-Systeme



- Intrusion detection (IDS) and response (IRS) system realizes automatic detection and response to attacks
- Analysis methods based on log or recorded information:
 - **Signature analysis:** System detects predefined patterns
 - Example: Detection of patterns for DoS attacks via SYN flooding
 - **Anomaly detection:**
 - Detection of normal behavior and deviations from this behavior using statistical analysis
- **Attack detector:** Module performs analysis of the information received and filtered by the packet capture module
- **Response module:** Initiates system response, e.g. blocking ports for a specific IP address

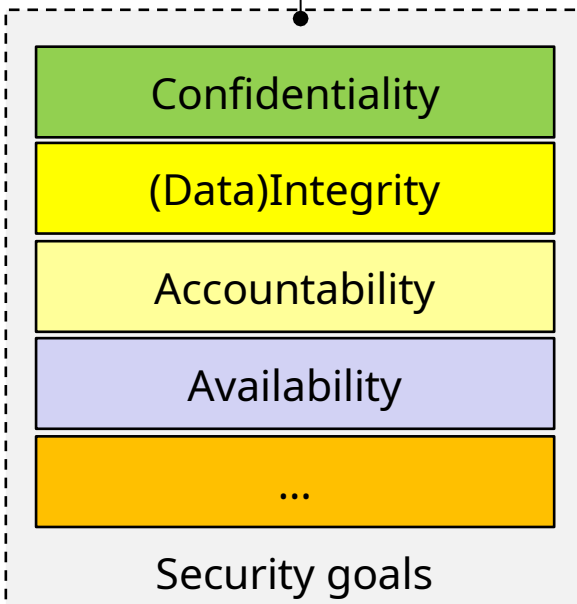
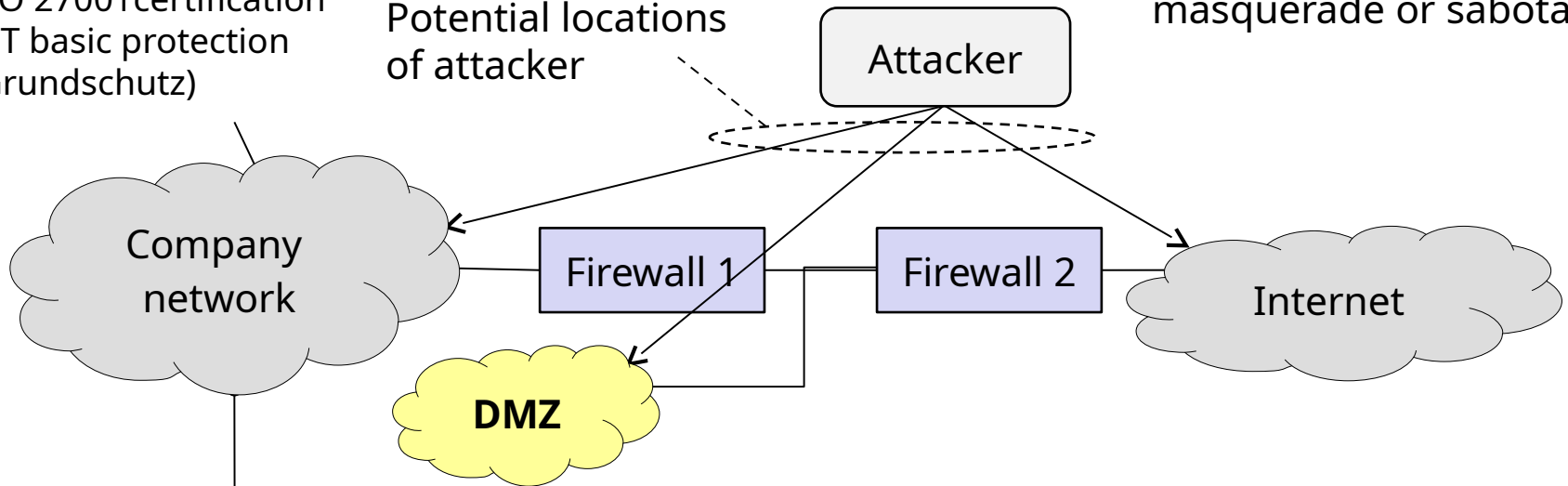


Summary

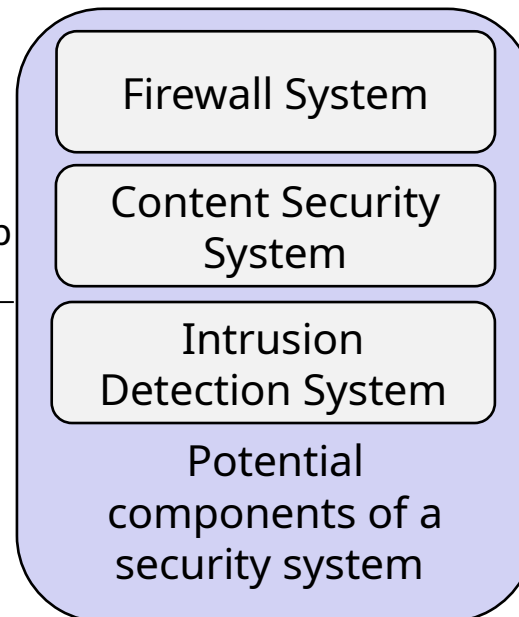
ISO 27001 certification
/ IT basic protection
(Grundschutz)

Potential locations
of attacker

- Realization of threats, e.g. masquerade or sabotage



Should help
to achieve
goals



Option: Use of Netfilter /
Iptables; Netfilter allows
registration of callback
functions at specific
processing points for
packets:

- PREROUTING
- INPUT
- OUTPUT
- FORWARD
- POSTROUTING

References

Selected RFCs

- Security Architecture for the Internet Protocol <https://tools.ietf.org/html/rfc4301>
- IP Authentication Header (AH) <https://tools.ietf.org/html/rfc4302>
- IP Encapsulating Security Payload (ESP) <https://tools.ietf.org/html/rfc4303>
- Transport Layer Security (TLS) Protocol <https://tools.ietf.org/html/rfc8446>

Links

- Wireguard Web page: <https://www.wireguard.com>
- "WireGuard: Next Generation Kernel Network Tunnel" by J. A. Donenfeld: <https://www.wireguard.com/papers/wireguard.pdf>
- Fundamental overview of BSI basic protection: https://www.bsi.bund.de/EN/Themen/Unternehmen-und-Organisationen/Standards-und-Zertifizierung/IT-Grundschutz/it-grundschutz_node.html
- Netfilter project: <https://www.netfilter.org/>
- Manpage of *ssh*: <https://linux.die.net/man/1/ssh>
- Manpage of *iptables*: <https://linux.die.net/man/8/iptables>